

AI PACKAGE HALLUCINATION TO ROOT

VALIDATED LAB BASELINE

react-codeshift 1.3.1
Ubuntu 22.04 + needrestart
3.5-5ubuntu2.1

237

GitHub repositories referenced
react-codeshift before the package
existed.

576K

Code samples studied across 16 LLMs
at USENIX Security 2025.

5.2% / 21.7%

At least average hallucination rates
reported for commercial /
open-source models.

7.8 HIGH

Ubuntu CVSS for CVE-2024-48990
local privilege escalation.

ATTACK CHAIN

1 AI instruction

Skill or generated
guidance contains a
plausible but
unverified package
name.

2 Name claimed

The prepared name is
published to the
isolated
npm-compatible
registry.

3 npx execution

The developer or
agent resolves and
executes the package
as a normal user.

4 Fixture armed

A visible developer
Python process
preserves the
controlled import
condition.

5 APT scans

A later administrative
package transaction
starts vulnerable
needrestart.

6 Root proof

The marker runs with
EUID 0 and activates
visible, bounded
state telemetry.

WHAT THE RECEIVER PROVES

armed-alive

Package execution and resident state under the
developer UID/EUID.

needrestart-root-execution

The vulnerable scanner loaded the marker with
UID/EUID 0.

root-persistence-alive

The visible root-owned state service remains active
after the transition.

FROM CLAIM TO EVIDENCE

External research + vendor advisory + isolated lab observations

Real-world evidence

1 react-codeshift - exact precedent [1]

Before the package existed, AI-generated skills referenced it across 237 repositories. After defensive registration, sustained downloads showed active resolution attempts. This lab reproduces the same package name and npx pattern.

2 huggingface-cli - independent validation [2]

After models repeatedly hallucinated the name, Lasso registered an empty package. It drew 30,000+ authentic downloads in three months and appeared in Alibaba documentation.

3 unused-imports - malicious analogue [3]

Confirmed malware occupied a plausible hallucinated npm name and still drew about 233 weekly downloads. AI-driven installation is plausible, not proven.

RELATED DFIR REFERENCE

Nx SIngularity [4] is retained only as a post-install DFIR analogue for npm cache, shell-profile and credential artifacts.

CVE and lab proof

VENDOR FACT

Ubuntu describes CVE-2024-48990 as attacker-controlled PYTHONPATH leading needrestart to execute arbitrary code as root. Jammy is fixed in 3.5-5ubuntu2.2.

RESEARCHER DISCLOSURE

Qualys documents that needrestart reads a local process environment and starts Python during interpreter scanning. The disclosure explains why an unprivileged process can influence a root scanner.

OUR ISOLATED OBSERVATION

Version 1.3.1 produced a developer event, then an EUID 0 marker after an ordinary APT transaction. The implementation used fixed-destination telemetry and created no shell, user, key, credential collector, or command channel.

ATT&CK and defensive action

T1195.002 - Compromise Software Supply Chain
T1068 - Exploitation for Privilege Escalation
T1543.002 - Systemd Service

PRIORITY CONTROLS

1. Verify package existence, owner, age and provenance before execution.
2. Treat agent skills and generated commands as code requiring review.
3. Pin registries and dependencies; restrict package-manager egress.
4. Patch needrestart or disable interpreter scanning per vendor guidance.
5. Correlate package execution, unusual child processes, user services, APT and root network events.

REFERENCES

[1] Aikido: react-codeshift investigation (2026)

[2] Lasso: AI Package Hallucinations (2024)

[3] Aikido: Slopsquatting and unused-imports (2026)

[4] Nx: SIngularity postmortem (2025)

[5] Spracklen et al.: USENIX Security 2025

[6] Ubuntu: CVE-2024-48990 advisory

[7] Qualys: needrestart technical advisory (2024)

[8] MITRE ATT&CK: T1195.002, T1068, T1543.002